

Stoquify Enterprise Proof-Driven Architecture Assessment

Date: 2026-07-24 Mode: read-only repository assessment and enterprise planning Implementation performed: no Full verification suite executed for this assessment: no

1. Executive Verdict

Enterprise transformation program: GO_WITH_GATES Unrestricted enterprise production claim: NO_GO Statutory or authority-certified claim: NO_GO Controlled bounded implementation slices: GO_WITH_GATES

Stoquify is not a generic CRUD application waiting for an enterprise rewrite. It already contains a serious financial and operational control foundation:

- tenant-scoped domain services;
- RBAC and fresh-auth seams;
- POS and offline replay controls;
- inventory event posting and reconciliation;
- purchasing/AP maker-checker workflows;
- payment reconciliation and suspense;
- journal, period, ledger, and close-assurance models;
- HRIS-to-payroll proof contracts;
- deterministic hashes, business events, outboxes, audit records, and evidence exports;
- workflow-assurance findings and incidents;
- extensive static gates and focused tests.

However, current evidence does not justify describing the entire platform as enterprise-production-ready. The largest blockers are:

1. The current working tree contains extensive uncommitted, overlapping work, so several current artifacts are not bound to a clean authoritative revision.
2. Module entitlements are derived from legacy/requested-module data rather than a durable commercial entitlement source of truth.
3. Statutory country-pack production readiness is explicitly blocked by source-artifact hash verification and expert approval.
4. Production-secret readiness remains conditional.
5. HRIS is a controlled People Core but still relies heavily on payroll-named compatibility storage.
6. Cross-domain close invalidation is strong but not proven complete for every close-impacting writer.
7. Provider, authority, hardware, backup/restore, deployment, alert acknowledgement, and legal evidence remain external dependencies.
8. The architecture graphs predate the latest agent-runtime work.

The correct strategy is a staged proof-driven modernization program. Each slice must establish one authoritative owner, one guarded write path, deterministic evidence, reversal/invalidation behavior, and a release gate before expanding scope.

2. Evidence Inspected And Freshness

Repository state

`git status --short` shows a large active worktree with modified and untracked files across:

- Prisma schema and migrations;
- CI configuration;
- permissions;
- agent runtime and assurance services;
- UI and actions;
- readiness artifacts;
- browser tests and reports.

Existing changes must be treated as user-owned active work. A new cross-cutting implementation should not begin until ownership, intended commit boundaries, and authoritative evidence are reconciled.

Architecture graphs

The ordered graph run dated 2026-07-14 contains:

- 6,380 nodes;
- 9,474 links;
- 3,320 service nodes;
- 928 component nodes;
- 757 action nodes;
- 526 app/route nodes;
- 408 library nodes;
- 255 hook nodes;
- 115 Prisma extraction nodes;
- 72 type nodes.

The graph is useful for established architecture but stale for July 22–24 agent-runtime changes.

Relevant graph communities:

- Services Community 42: module catalog, normalization, legacy-entitlement derivation, entitlement evaluation, and Module Control Center.
- Actions Community 44: analytics report input and financial/cashier/item/cash-flow report actions.
- App Community 28: analytics route.
- Consolidated graph and service graph show assurance hashes, business payload hashes, trusted read models, payroll proof execution, and accountant-portal data as major hubs.

Current readiness artifacts

Current report outputs inspected:

Evidence	Generated	Reported status	Assessment boundary
Ledger Close Truth	2026-07-24	ready, 10/10	Static internal posting/close evidence seams
Payment Cash Truth	2026-07-24	ready, 10/10	Internal provider-evidence controls, not live provider certification
Purchasing/AP Consolidation	2026-07-24	ready, 10/10	Internal control seams, not supplier/bank/statutory certification

Evidence	Generated	Reported status	Assessment boundary
Offline POS Fiscal Replay	2026-07-24	ready, 10/10	Internal replay controls, not hardware/connectivity/authority proof
Report Trust And Export	2026-07-24	ready, 9/9	Provenance and integrity, not statutory filing certification
Public Identity Abuse	2026-07-24	ready, 15/15	Repository control boundary
Role-Based Cockpit	2026-07-24	ready, 9/9	Daily Digest slice only
API Route Inventory	2026-07-24	ready, zero issues	Inventory currently misses semantic classification of one guarded internal route
Prisma Migration Readiness	2026-07-24	ready, 8/8	Migration policy evidence
CI Release Readiness	2026-07-24	ready, 11/11	Repository CI configuration, not provider branch/promotion policy
Payroll Immutability Runtime	2026-07-24	ready	Controlled runtime evidence
Statutory Country Pack	2026-07-24	blocked, 10/12	Missing artifact hash verification and expert approval
Release Secret Preflight	2026-07-24	conditional, 2/8	Production secrets absent from the local environment
Module Surface Inventory	2026-07-22	ratchet passed	Ten active gaps remain; entitlement enforcement is not complete

Representative source inspected

- `prisma/schema.prisma`
- `services/modules/module-entitlement.service.ts`
- `services/modules/module-control-contracts.ts`
- `services/_shared/protect.ts`
- `lib/security/server-authz.ts`
- `services/pos/pos.service.ts`
- `services/pos/offline-sync.service.ts`
- `services/inventory/inventory-stock-event.service.ts`
- `services/inventory/inventory-adjustment-reversal.service.ts`
- `services/purchasing/ap-control.service.ts`
- `services/hris/payroll-readiness-contract.ts`
- `services/payroll/certified-input-proof.ts`
- `services/accounting/posting.service.ts`
- `services/accounting/journal-close-invalidation.service.ts`
- `services/accounting/close-assurance.service.ts`
- `services/accounting/close-assurance-pack.service.ts`
- `app/api/internal/agents/reconcile-abandoned/route.ts`
- `actions/analytics/financial-reports.ts`
- `app/[locale]/(dashboard)/dashboard/analytics/reports/page.tsx`

Representative focused tests and current execution reports were inspected. This assessment did not rerun Jest, Playwright, typecheck, migrations, builds, or policy gates because the governing prompt required read-only discovery and the working tree is active.

3. Capability And Maturity Matrix

Classification:

- **PROVEN:** current code plus focused/gate evidence for a bounded internal claim.

- **IMPLEMENTED_NOT_PROVEN**: implementation exists but production/runtime/external proof is incomplete.
- **PARTIAL**: important bounded slices exist, but the complete domain is not closed.
- **DOCUMENTED_ONLY**: not enough code evidence.
- **EXTERNAL_DEPENDENCY**: proof must come from outside the repository.
- **CONTRADICTED_OR_STALE**: evidence disagrees or predates current source.

Capability	Classification	Evidence-backed assessment
Tenant-scoped RBAC foundation	PROVEN for inspected boundaries	Shared permission context, organization checks, critical-permission mapping, protected actions, and route guards exist. Coverage is not equivalent to proof for every surface.
Module catalog and observation	PROVEN	Canonical catalog, dependency metadata, observe logs, control center, and surface inventory exist.
Durable module entitlement truth	PARTIAL	Entitlements are derived from requestedModules, defaults, or explicit in-memory input. There is no persistent entitlement model.
Platform-wide module enforcement	PARTIAL	Shared action/API enforcement seams exist, but the system reports <code>hardEnforcementEnabled: false</code> ; inventories still have gaps.
POS online sale and shift controls	PROVEN for internal workflows	Tenant-scoped sessions, business events, outbox hashes, replay/conflict checks, and shift-close evidence exist.
Offline POS replay	IMPLEMENTED_NOT_PROVEN	Internal static gate is ready with exact-once and quarantine controls. Real device, connectivity, fiscal-authority, and recovery drills remain unproven.
Inventory event truth	PROVEN for inspected posting paths	Opening stock, receipts, POS issues/returns, transfers, adjustments, events, outboxes, period checks, and idempotency tests exist.
Inventory physical/operational truth	IMPLEMENTED_NOT_PROVEN	Physical counts, device operations, projection rebuild, and valuation need production-volume, failure-recovery, and operational evidence.
Purchasing/AP	PROVEN for internal control chain	PO maker-checker, receipt/stock posting, three-way match, supplier bank approval, payment approval/release segregation, hashes, ledger links, and invalidation seams exist.
Supplier/bank execution	EXTERNAL_DEPENDENCY	Live bank/provider settlement, bank-account verification, supplier confirmation, and fraud operations need external evidence.
Payment reconciliation	PROVEN for internal evidence chain	Provider readiness contract, deterministic source hash, signed evidence, drift invalidation, suspense, and policy wiring are present.
Accounting ledger and period controls	PROVEN for inspected internal paths	Balanced posting, open-period checks, posting idempotency, source links, reversal, audit evidence, and close invalidation exist.
Close Assurance	PROVEN as internal accountant-review evidence	Durable close runs, findings, evidence, hashes, pack exports, segregation of duties, and blocker logic exist. It is not statutory certification.
Cross-domain close invalidation mesh	PARTIAL	Multiple domain invalidation services exist. Complete coverage for every ledger/payment/inventory/payroll/AP/tax/export writer is not yet proven.
HRIS People Core	PARTIAL	HRIS services, routes, actions, org/position models, lifecycle, approvals, documents, self-service, and payroll-readiness contracts exist.
Full enterprise HRIS	PARTIAL	Durable compatibility storage remains payroll-named; permissions, time/leave operations, document vault, benefits, and extended HR modules remain incomplete.
Payroll certified input	PROVEN for controlled internal contract	HRIS identity, contract, document, compensation, payment-destination, attendance, maker-checker, and source-hash checks fail closed.

Capability	Classification	Evidence-backed assessment
Payroll calculation/payment/declaration	IMPLEMENTED_NOT_PROVEN	Strong internal lifecycle and evidence exist. Production country packs, payment providers, authority submission, and unrestricted rollout remain unproven.
Country-pack compliance	PARTIAL/BLOCKED	Fail-closed framework exists. Production artifact hash verification and qualified expert approval are missing.
Trusted reports and exports	PROVEN for inspected accounting/report slice	Versioned manifests, period/currency/provenance, redaction, hashes, fresh auth, and audit evidence are gated.
Role operating cockpits	PARTIAL	Daily Digest slice is gated and ready; this does not prove all owner, manager, accountant, cashier, HR, payroll, or compliance cockpits.
Workflow Assurance	IMPLEMENTED_NOT_PROVEN at platform level	Registry, checks, findings, incidents, alerts, waivers, and control-tower services exist. Production alert delivery and acknowledgement remain incomplete.
Controlled AI agent runtime	PARTIAL	Deterministic read-only Command Agent and release controls passed local focused tests. Real internal activation remains blocked.
CI and migration configuration	PROVEN as repository configuration	Current configuration gates pass. Branch protection, deployment promotion, and provider-side enforcement remain external.
Production operations	EXTERNAL_DEPENDENCY/PARTIAL	Secret, scheduler, alert, backup/restore, DR, monitoring, capacity, and on-call evidence is incomplete or external.

4. Domain Source-Of-Truth Registry

Domain fact	Authoritative owner	Allowed writers	Consumers	Current risk
Tenant identity and membership	Organization/Auth	Auth and governed organization services	All modules	Session claims and entitlement truth must remain distinct
Permissions and role assignment	RBAC control plane	Protected role/permission services	Routes, actions, APIs, agents	Inventory coverage is broad, not absolute
Module availability	Target: persistent Module Control Plane	Target: protected entitlement lifecycle service	Navigation, pages, actions, APIs, jobs, reports	Current truth is derived from legacy/requested-module state
Product/item master	Inventory	Inventory item services	POS, purchasing, reporting	Some legacy action surfaces remain
Stock movement	Inventory event services	Receipt, POS, transfer, count, adjustment gateways	Availability, valuation, close	Reservation fallback uses a time-derived key when no key is supplied
POS terminal sale	POS service/server replay	Protected POS and offline replay services	Inventory, payment, ledger, fiscal evidence	External device and fiscal proof incomplete
Purchase commitment	Purchasing	Purchase-order workflow	Receipt, AP, inventory	Cross-module dependencies must remain explicit
Goods receipt	Purchasing plus Inventory posting gateway	Receipt service transaction	Inventory, invoice matching, AP, close	Operational receiving/device proof external
Supplier invoice and match	Purchasing/AP	AP control service	Ledger, payment, close	Live supplier document authenticity external
Supplier payment	Purchasing/AP with payment/reconciliation integration	Separate request, approval, and release actors	Reconciliation, ledger, close	Bank/provider execution external
Provider settlement	Reconciliation/payment domain	Ingestion and controlled match/sign-off services	Cash truth, payroll/AP, close	Live provider access and statement completeness external
Employee and employment facts	HRIS	HRIS People Core services	Payroll, manager/self-service, accounting dimensions	Compatibility rows are still payroll-named
Certified payroll inputs	HRIS-to-payroll readiness contract	HRIS certification process	Payroll engine	Needs refreshed production-readiness evidence
Payroll result	Payroll	Payroll run/control services	Payslips, payment, declaration, accounting	Country-pack and external execution proof incomplete
Journal and balance truth	Accounting/Ledger	Posting and reversal services	Reports, reconciliation, close, compliance	Complete invalidation mesh needs proof
Statutory interpretation	Versioned Country Pack	Expert-reviewed publish workflow	Payroll, fiscal documents, compliance	Production publish gate blocked
Evidence and blockers	Assurance	Domain evaluators and assurance services	Operators, reviewers, close, release	Assurance must never become a parallel business writer

5. Cross-Domain Proof Chains

POS → Inventory → Payment → Ledger → Fiscal → Close

Strengths:

- POS commit and shift close use tenant scope, transactions, business events, outbox records, payload hashes, and replay/conflict logic.
- Inventory POS issue/return posting has deterministic domain idempotency keys.
- Offline replay gate checks device scope, sequence/hash chains, quarantine, pending-replay proof, and exact-once finalization.
- Accounting posting and close evidence seams exist.

Broken or externally unproven links:

- real terminal identity, clock behavior, durable browser storage, device loss, and network-partition recovery;
- live cash/card/mobile-money settlement completeness;
- production fiscal-device/authority delivery and acknowledgement;
- end-to-end chaos proof from offline capture through final close;
- proof that every post-certification POS/fiscal correction invalidates affected close artifacts.

Purchasing → Receipt → Inventory → Invoice → Match → AP → Payment → Reconciliation → Close

Strengths:

- purchase-order maker-checker;
- atomic goods-receipt stock posting;
- evidence-preserving line cleanup;
- supplier invoice receipt and variance controls;
- three-way-match evidence;
- ledger source and audit proof;
- supplier bank-destination approval;
- separate payment requester, approver, and releaser;
- payment/reconciliation and close-invalidation seams.

Broken or externally unproven links:

- supplier document authenticity and duplicate detection at production scale;
- bank-account ownership verification;
- live payment-provider submission and settlement confirmation;
- operational exception ownership and SLA evidence;
- complete close invalidation after every AP evidence mutation.

HRIS → Certified Snapshot → Payroll → Payment/Declaration → Accounting → Close

Strengths:

- HRIS readiness exports carry identity, contract, document, compensation, payment-destination, and attendance proof.
- Maker-checker identity separation and source hashes are checked.
- Payroll certified-input metadata fails closed on missing or stale proof.
- Payroll immutability runtime evidence currently reports ready.
- Payroll register/export and declaration/payment services contain hashes, idempotency, business events, and outboxes.

Broken or externally unproven links:

- HRIS still relies on payroll-named compatibility storage for important people facts;
- older HRIS release evidence is stale relative to the July 24 successful typecheck;
- production country-pack approval remains blocked;
- live payroll payment-provider and authority submissions remain external;
- real employee/manager/privacy operations, document-vault controls, retention, and legal holds require broader proof.

Certified Evidence Change → Invalidation → Blocker → Correction → Refreshed Pack

Strengths:

- journal, inventory, reconciliation, payroll, and AP invalidation seams exist;
- reconciliation drift and close-pack staleness are modeled;
- reversals and correction evidence are preferred over destructive edits;
- close pack certification checks source state and blockers.

Gap:

There is no current single evidence artifact proving that every close-impacting writer across ledger, payments, reconciliation, suspense, inventory valuation, payroll, AP, tax, fiscal documents, and trusted exports participates in the invalidation mesh.

6. Risk Register

Priority	Risk	Impact	Required response
P0	Dirty worktree and evidence not bound to one clean revision	False readiness, lost changes, unreproducible certification	Establish ownership and a clean evidence baseline before cross-cutting work
P0	No persistent module entitlement truth	Commercial leakage, inconsistent access, package drift	Add durable entitlement lifecycle and pilot enforcement
P0	Country-pack expert/hash blockers	Incorrect payroll/tax/fiscal automation	Keep production automation fail-closed; obtain reviewed artifacts
P0	Conditional production secrets	Token forgery or unsafe fallback risk if deployed incorrectly	Configure separate strong production secrets and rerun release mode
P1	Full close invalidation mesh not proven	Certified packs can become silently stale	Build writer registry and invalidation coverage gate
P1	HRIS/payroll storage ownership ambiguity	Parallel truth, unsafe migrations, employee/payroll drift	Execute versioned HRIS ownership migration with compatibility window
P1	Internal agent operational activation incomplete	Unowned automation, missed alerts, uncontrolled drift	Keep activation blocked until real approvals, scheduler, alerts, and clean CI proof
P1	Surface inventory parser/semantic gaps	False assurance about authorization/module coverage	Replace malformed heuristic findings with AST/registry evidence
P1	Time-derived inventory reservation fallback key	Retry may create duplicate reservations	Require caller-provided stable idempotency key or deterministic command identity
P2	Stale architecture graph	Incorrect impact analysis	Refresh graph after active work is stabilized
P2	Cockpit readiness applies to one slice	Overstated role-based operations maturity	Certify each role workspace separately
P2	Provider/hardware/authority proof absent	Repository tests mistaken for production assurance	Maintain explicit external-evidence register and deployment gates
P2	Backup, restore, DR, capacity, and on-call evidence incomplete	Operational failure and slow recovery	Add production-readiness drills and evidence packs

7. Contradictions And Stale Claims

1. The 2026-07-19 HRIS analysis says full typecheck is blocked by V8 OOM. The 2026-07-24 agent-runtime report records a successful full typecheck using an 8 GB heap. The technical blocker may be resolved, but HRIS final-readiness evidence has not been refreshed.
2. The API inventory reports ready with zero issues while `app/api/internal/agents/reconcile-abandoned/route.ts` remains unclassified and `review_required`. Source inspection shows a fail-closed configured-secret check and bearer authorization, so this is an inventory-classification gap rather than an unguarded route.
3. The module-surface ratchet reports passed, but ten active gaps remain: five unmapped and four missing-permission records plus other classifications. "Ratchet passed" means no new regression, not complete enforcement.
4. `services/modules/module-entitlement.service.ts` reports `hardEnforcementEnabled: false`, derives access from requested/legacy defaults, and lacks a persistent entitlement source even though shared action/API guards can

request enforce mode.

5. Current static gates report multiple domains ready, but their own safety sections explicitly exclude provider, statutory, hardware, and external certification.
6. The July 14 graphs are useful for established code but do not represent the current agent-runtime implementation.
7. The latest local agent certificate records a base commit that does not include the dirty implementation. The report correctly calls the certificate provisional until reproduced on a clean committed revision in CI.

8. Target Enterprise Architecture

A. Identity and tenant control plane

- organization and user truth;
- role and permission policy;
- session freshness;
- resource and location scope;
- durable module entitlement lifecycle;
- package/subscription provisioning;
- immutable access-decision evidence.

B. Domain command plane

Each domain owns its write model and exposes guarded commands:

- POS;
- inventory;
- purchasing/AP;
- payments/reconciliation;
- HRIS;
- payroll;
- accounting;
- compliance.

UI components and reports may request commands or read models but must never write authoritative state directly.

C. Business-event spine

Every material accepted command produces:

- stable command/idempotency identity;
- domain record mutation;
- business event;
- outbox message where downstream delivery is needed;
- correlation ID;
- actor/tenant/resource scope;
- payload/source hash;
- applied/failed/replayed state.

D. Projection and accounting plane

- inventory projections derive from stock events;
- cash and provider truth derive from reconciliation evidence;
- payroll consumes certified HRIS snapshots;
- accounting consumes controlled source links and balanced posting rules;
- read models disclose provenance and freshness.

E. Proof and assurance plane

- evidence manifests;
- deterministic content hashes;
- findings, exceptions, suspense, and owners;
- invalidation when source data changes;
- review, waiver, and maker-checker decisions;
- exportable proof packs;
- explicit POSTED, OPERATIONAL, ESTIMATED, STALE, UNAVAILABLE, and EXTERNALLY_UNVERIFIED states.

Assurance evaluates domain truth. It does not become a second writer of business facts.

F. Country-pack and external-adapter plane

- versioned and effective-dated country packs;
- source artifact hashes;
- qualified expert approval;
- sandbox/certification/production adapter separation;
- fail-closed unsupported automation;
- authority/provider acknowledgement and replay evidence.

G. Operations and release plane

- clean-commit CI certification;
- migration safety;
- production-secret preflight;
- deployment promotion policy;
- scheduler/worker leases;
- monitoring and alert acknowledgement;
- backup/restore and disaster-recovery drills;
- capacity and latency evidence;
- controlled pilot and rollback.

9. Prioritized Program Roadmap

Phase 0 — Evidence Baseline And Worktree Reconciliation

Goal: establish an authoritative starting point.

- Identify owners and intended commit boundaries for current changes.
- Preserve all unrelated work.

- Refresh status registers after approved stabilization.
- Rerun typecheck, focused tests, migrations, policy gates, and evidence scans on a clean revision.
- Refresh graph artifacts after the source baseline is stable.

Exit gate:

- clean or deliberately partitioned worktree;
- reproducible commit SHA;
- current gate bundle;
- evidence manifest listing environment and skipped checks.

Phase 1 — Durable Module Entitlement Control Plane

Goal: create one tenant/module commercial access truth.

- Add persistent tenant module entitlements with lifecycle, effective dates, source, version, read-only/trial state, and audit lineage.
- Backfill legacy/requested-module state deterministically.
- Centralize decisions through the shared guard contract.
- Preserve RBAC as a separate authorization dimension.
- Pilot enforcement on a bounded read-only analytics surface.
- Keep core operational modules in observe mode during the pilot.

Phase 2 — Domain Truth And Writer Registry

Goal: make write ownership machine-verifiable.

- Register authoritative models and allowed writers.
- Gate direct cross-domain writes.
- Require explicit service gateways for stock, payment, payroll, and ledger effects.
- Add release ratchets for new unowned writers.

Phase 3 — Close Invalidation Mesh

Goal: prove that certified evidence cannot silently become stale.

- Inventory every close-impacting write.
- Require invalidation or explicit non-impact classification.
- Test each writer-to-close path.
- Produce a machine-readable invalidation coverage report.

Phase 4 — POS And Inventory Operational Certification

- Real offline device and durable storage tests.
- Network partition, duplicate, fork, clock, revocation, and recovery drills.
- Physical count and projection-rebuild proof.
- Stable idempotency for reservations.
- Fiscal/provider sandbox evidence.

Phase 5 — Purchasing, AP, Cash, And Provider Operations

- Live/sandbox provider adapter certification.

- Supplier bank ownership and change-control proof.
- Settlement exception and SLA workflows.
- End-to-end AP-to-close certification.

Phase 6 — HRIS Ownership Migration And Payroll Closure

- Refresh People Core final readiness.
- Introduce HRIS-owned durable models with compatibility mapping.
- Expand fine-grained HRIS permissions.
- Complete time/leave, document vault, retention, and manager workflows.
- Re-certify HRIS snapshot → payroll → payment/declaration → accounting → close.

Phase 7 — Country-Pack Production Readiness

- Hash and retain authoritative source artifacts.
- Obtain qualified expert review and approval.
- Version/effective-date all rules.
- Certify sandbox adapters before production.
- Keep unsupported jurisdictions and periods fail-closed.

Phase 8 — Production Operations And Controlled Rollout

- Configure dedicated secrets.
- Bind scheduler and worker identities.
- Prove alert delivery and acknowledgement.
- Run backup/restore and DR exercises.
- Prove branch protection and deployment promotion.
- Execute bounded customer/branch pilots with rollback evidence.

10. Recommended Next Bounded Implementation Slice

Slice

Persistent module entitlement foundation plus read-only Analytics enforcement pilot.

Preconditions

- Current agent-runtime and schema work is assigned to an owner and stabilized.
- The slice runs from a clean or deliberately isolated revision.
- Existing requestedModules behavior is captured as a migration fixture.

Why this slice

- It closes the largest platform-wide source-of-truth gap.
- It reduces commercial feature leakage.
- It exercises the shared guard contract without risking POS, inventory, payroll, accounting, or compliance writes.
- Analytics is a bounded read-only module with existing permission and route tests.
- The architecture graph already identifies:
- Services Community 42 for module evaluation;

- Actions Community 44 for analytics reports;
- App Community 28 for the analytics page.

Expected affected files

Core:

- `prisma/schema.prisma`
- a new additive `prisma/migrations/<timestamp>_module_entitlement_foundation/migration.sql`
- `services/modules/module-control-contracts.ts`
- `services/modules/module-entitlement.service.ts`
- `services/modules/module-catalog.service.ts`
- `services/_shared/protect.ts`
- `lib/security/server-authz.ts`
- `actions/modules/module-control.actions.ts`

Pilot surfaces:

- `actions/analytics/financial-reports.ts`
- `actions/analytics/financial-analytics.ts`
- `actions/analytics/getSalesAnalytics.ts`
- `app/[locale]/(dashboard)/dashboard/analytics/page.tsx`
- `app/[locale]/(dashboard)/dashboard/analytics/reports/page.tsx`

Tests and gates:

- `services/modules/__tests__/module-entitlement.service.test.ts`
- `services/_shared/__tests__/protect.test.ts`
- analytics action authorization tests;
- analytics route tests;
- module surface inventory tests;
- a new bounded module-entitlement pilot gate and evidence artifact.

Success criteria

1. One durable entitlement row is authoritative for an organization/module/effective version.
2. Active, read-only, suspended, expired, and unavailable states are deterministic.
3. RBAC wildcard or superuser status does not silently bypass missing module entitlement.
4. Analytics navigation, page, action, and API/read services agree on the decision.
5. Suspended or expired analytics access returns a safe denial before data reads.
6. Read-only entitlements permit reads and block writes.
7. Legacy/requested-module tenants receive a deterministic backfill without accidental loss of access.
8. Every entitlement lifecycle change records actor, reason, source, correlation, and audit evidence.
9. Core modules remain unchanged or observe-only during the pilot.
10. Rollback can disable pilot enforcement without deleting entitlement evidence.

11. Migration, Backfill, And Rollback

Migration

Use an additive model. Do not delete or reinterpret `Organization.requestedModules` in the first slice.

Recommended durable concepts:

- organization;
- module slug;
- lifecycle status;
- effective start/end;
- read-only/trial flags;
- source and source reference;
- version;
- reason/metadata;
- created/updated actor and timestamps;
- supersession or immutable lifecycle evidence.

Exact schema naming should be decided after checking current naming conventions and migration ownership.

Backfill

1. Produce a dry-run report from current `requestedModules` and legacy-default behavior.
2. Calculate deterministic proposed rows.
3. Report unknown module slugs, dependency gaps, and access changes.
4. Require zero unexplained access loss before applying.
5. Apply idempotently.
6. Reconcile row counts and decision equivalence.

Rollback

- Switch the analytics pilot back to observe mode.
- Preserve entitlement and audit rows.
- Do not destructively restore legacy state.
- Use a forward corrective migration for schema defects.

12. Verification Matrix

Layer	Required verification
Schema	Prisma validate, additive migration safety, uniqueness and tenant relations
Service	Status/effective-date/dependency evaluation; deterministic legacy backfill
Security	Tenant isolation, RBAC plus entitlement composition, no wildcard bypass
Actions	Analytics denial occurs before service read; safe error envelope
Routes/UI	Hidden, unavailable, suspended, read-only, and active states
Idempotency	Repeated provisioning/backfill produces no duplicate entitlement
Audit	Actor, reason, source, prior/new state, correlation, and timestamp
Regression	Core modules retain current behavior during pilot
Static gates	Module inventory has no new gaps and pilot surfaces are explicitly enforced
Runtime	PostgreSQL migration and tenant-isolation smoke
Browser	Allowed and denied analytics flows on desktop and mobile
Repository	Typecheck, focused lint, focused Jest, relevant policy gates
Evidence	Commit-bound manifest with commands, exit codes, hashes, environment, and skipped checks

13. Required Proof Artifacts

Store under a dedicated run folder such as:

`what-next/module-entitlement/runs/<run-id>/`

Required artifacts:

- baseline manifest;
- legacy entitlement dry-run JSON and Markdown;
- migration safety output;
- focused test results;
- tenant-isolation runtime smoke;
- analytics allowed/denied browser evidence;
- module inventory before/after comparison;
- audit evidence samples with sensitive values redacted;
- rollback exercise;
- final decision report;
- commit SHA and dirty-tree status;
- external or skipped-check register.

14. Human And External Decisions Required

Product/commercial

- Which modules are core, bundled, add-on, trial, or unavailable?
- What happens to historical read access after suspension or expiry?
- Which dependencies are required, recommended, commercial, technical, or evidence-only?

Accounting and assurance

- Which operational evidence may block close?
- Which evidence is informative versus certification-critical?
- Who may waive a blocker, for how long, and with what proof?

HR/payroll/privacy

- HRIS ownership migration and retention rules;
- sensitive-field access and export policy;
- country-specific payroll expert approval.

Security/operations

- production secret owners and rotation;
- scheduler/worker identity;
- alert destinations and acknowledgement SLAs;
- backup, restore, DR, and incident ownership.

Statutory

- qualified country-pack reviewers;
- authoritative source artifacts;
- legal limitations on offline fiscal behavior;
- authority adapter certification and production approval.

15. Final Decision

GO_WITH_GATES for the staged enterprise program.

NO_GO for claiming that the complete Stoquify suite is currently enterprise-production-ready, statutory-certified, or ready for unrestricted agent activation.

The next safe technical move is not a platform rewrite. It is:

1. stabilize and bind current work to clean evidence;
2. implement persistent module entitlement truth;
3. pilot enforcement on read-only analytics;
4. prove the pilot;
5. then expand one bounded domain at a time.

This assessment changed no production code and intentionally did not regenerate repository gates.